ClinicOS — System Blueprint

Front-to-back wiring for the consultation-documentation assistant: every page, component, API route, lib module, and the two local processes (ASR sidecar, Ollama) they call. Online, these use Postgres + hosted AI because none exists in the app.

DRAWN FROM **SRC/APP**, **SRC/LIB**, **SRC/COMPONENTS**
NEXT.JS 15 APP ROUTER · REACT 19 · SQLITE
REV. 2026-09-17

No diagnosis in the LLM box. llm.ts's SYSTEM_PROMPT records what the doctor said and decided — it does not generate a diagnosis or risk score.

Consent is a 403, not a greyed-out button. Every recording route re-reads `consentGiven` from the database before accepting audio.

draftJson is write-once. Edits live in workingJson; the diff at signing is the product's accuracy metric.

Audio dies with the signature. The unlink happens inside `sign/route.ts`, same transaction of intent as writing signedAt.

Middleware is a doorbell, not a lock. It only checks a cookie exists; every route re-derives the real permission via requireApiUser(capability).

Backups use Database.prototype.backup(). A WAL-mode file copy silently drops the newest consultations.

FIG. 1 — FULL SYSTEM MAP

Every layer, every connection

Client pages compose components, which call hooks, which fetch API routes. Every request — page or API — passes the Edge middleware gate first. Every route handler re-checks identity itself against three capabilities (clinical, frontdesk, admin) before touching the database. Below the API line, everything is a local process: SQLite on disk, a Python ASR sidecar, and Ollama — nothing here can reach the internet with patient data. Solid arrows are calls; dashed arrows are gate checks or return data; thick arrows carry every request through a checkpoint.

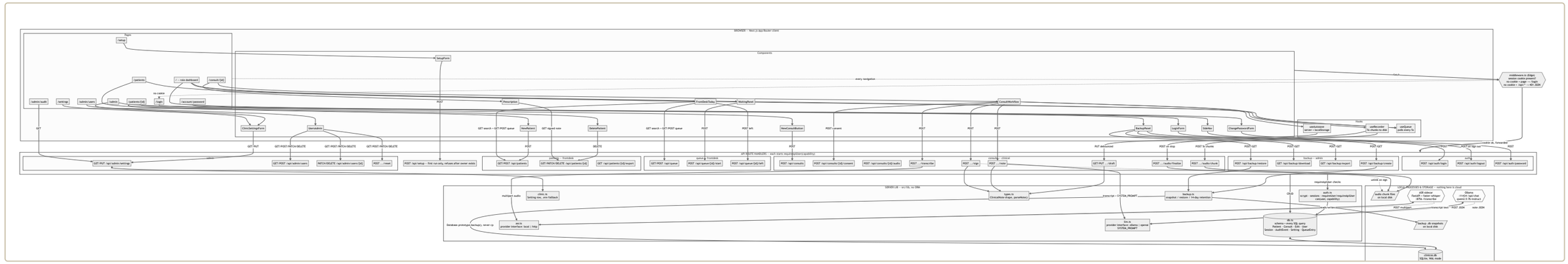
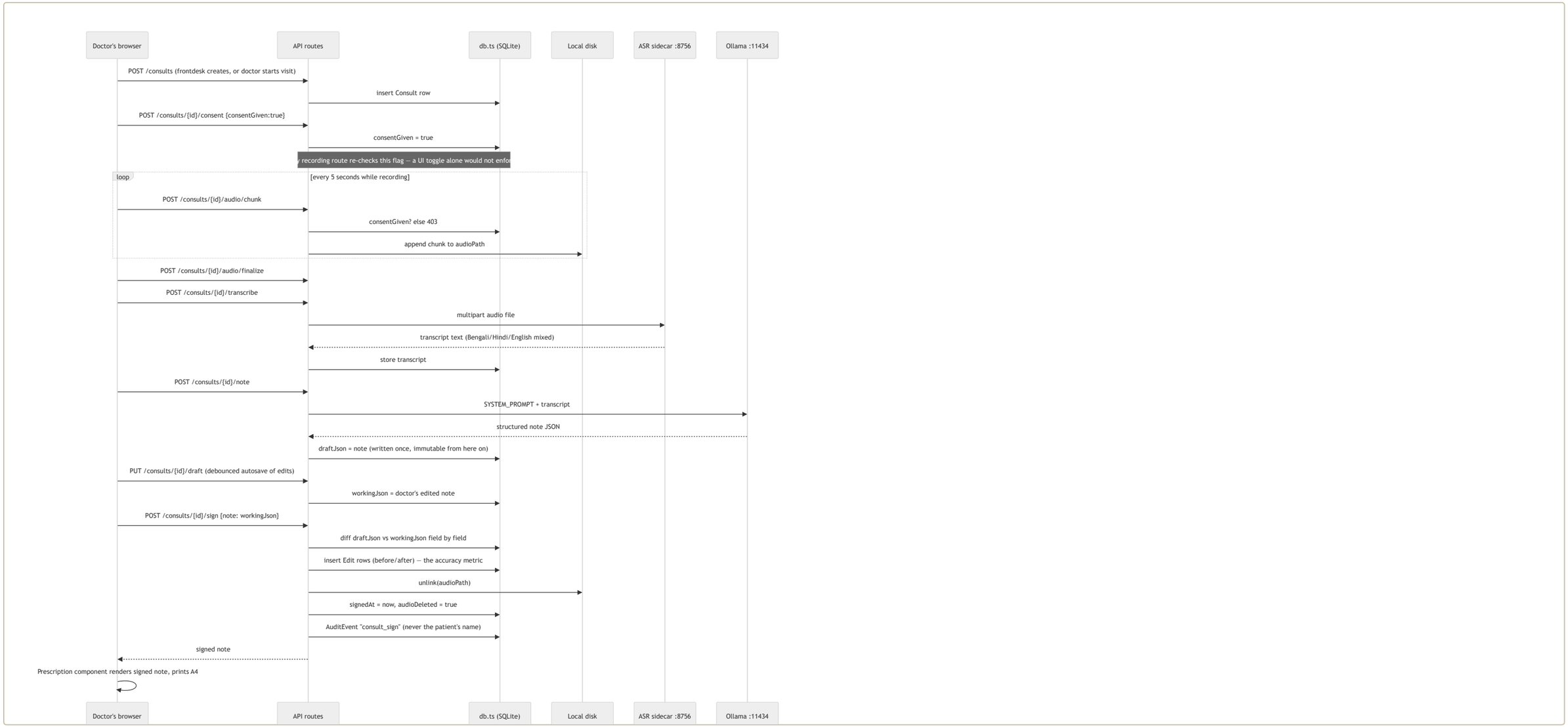


FIG. 2 — MECHANISM

One consultation, start to signed prescription

The sequence the architecture above exists to support. Consent is checked server-side before any audio byte is accepted; the draft is written once and never touched again; the doctor's edits land in a separate column; the raw audio is unlinked from disk in the same handler that writes the signature.



The audio delete near the end is invariant #3 in code, not policy: it runs inside the same handler that writes the signature, so there is no window where a signed consult still has audio sitting on disk.

REFERENCE

Every route, grouped as drawn in Fig. 1

API SURFACE — SRC/APP/API

ROUTE	CAPABILITY	BACKED BY
`POST /api/setup`	none (first run only)	db.ts — creates the owner account, then refuses forever
`POST /api/auth/login`	none	auth.ts — scrypt verify, issues session
`POST /api/auth/logout`	any session	auth.ts — clears session
`POST /api/auth/password`	any session	auth.ts
`GET/POST /api/patients`	frontdesk	db.ts
`GET/PATCH/DELETE /api/patients/{id}`	frontdesk	db.ts — DELETE requires typed-name confirm client-side
`GET /api/patients/{id}/export`	frontdesk	db.ts
`GET/POST /api/queue`	frontdesk	db.ts — QueueEntry
`POST /api/queue/{id}/start`	clinical	db.ts
`POST /api/queue/{id}/left`	frontdesk	db.ts
`POST /api/consults`	clinical	db.ts
`POST /api/consults/{id}/consent`	clinical	db.ts — server-side gate, invariant #5
`POST /api/consults/{id}/audio(/chunk,/finalize)`	clinical	filesystem — 403 if consentGiven is false
`POST /api/consults/{id}/transcribe`	clinical	asr.ts → ASR sidecar
`GET/PUT /api/consults/{id}/draft`	clinical	db.ts — workingJson only, never draftJson
`POST /api/consults/{id}/note`	clinical	llm.ts → Ollama, writes draftJson once
`POST /api/consults/{id}/sign`	clinical	db.ts + fs — diff, delete audio, sign
`GET/PUT /api/admin/settings`	admin	clinic.ts
`GET/POST /api/admin/users`, `{id}`, `{id}/reset`	admin	auth.ts + db.ts
`POST /api/backup/create`, `/restore`, `GET /download`, `/export`	admin	backup.ts — SQLite online backup API only

Generated from the repository at clinicos-app/src — every node name is a real file, route, or table; nothing here is illustrative.